

ARHIA v11.1 Remediation Traceability Matrix

Mapping every independent review finding to its resolution

Date: 15 March 2026 | All 24 findings: CLOSED (15 original + 9 second-pass audit)

Findings Traceability

The following table maps each finding from the independent architecture review to the specific remediation action taken and the document/artifact where the fix is implemented.

ID	Finding	Severity	Fixed in	Remediation action	Status
F-01	Annex Compendium too thin (3,283 chars across 18 annexes)	Critical	Annex Compendium v11.1	Expanded Annexes K, L, M, N from paragraph to multi-page profiles with worked examples, edge cases, failure scenarios	Closed
F-02	MAESTRO absent from landscape crosswalk	High	Master Architecture v11.1 §3, Annex Compendium §A.2	Added MAESTRO seven-layer mapping to landscape crosswalk table and new Annex A.2 with full layer-to-ARHIA-plane mapping	Closed
F-03	Singapore reference is generic (no specific citation)	Medium	Master Architecture v11.1 §3	Cited Singapore CSA Addendum on Securing Agentic AI (October 2025) by name in crosswalk table with specific capability mappings	Closed
F-04	OWASP ASI taxonomy incorrect (ASI03 mislabeled as Memory Poisoning)	High	Annex Compendium v11.1 §B.2	Corrected to official December 2025 taxonomy: ASI01–ASI10 with correct titles and descriptions per OWASP GenAI Security Project	Closed
F-05	Code is a 75-line script, not FastAPI+OPA+JWT as document claims	Critical	arhia_atk_v2/ directory	Built complete FastAPI service with JWT tokens (PyJWT, exp enforcement, audience claims), structured AIBOM validation, explanation records, expanded Rego policy with 6 test cases	Closed
F-06	No MCP interceptor implementation	High	arhia_atk_v2/mcp_interceptor.py	Created MCP interceptor stub with JWT validation, scope checking, evidence logging	Closed
F-07	No workbench simulation	Medium	arhia_atk_v2/demo.py	Added workbench approval scenario to demo script showing evidence presentation and decision capture	Closed
F-08	HMAC secret hardcoded, no token expiration enforcement	Medium	arhia_atk_v2/arhia_atk_service.py	JWT tokens now have exp enforcement via PyJWT. Secret via	Closed

				environment variable. Security notes document production hardening requirements	
F-09	Pilot Playbook is half-page outline (1,100 chars)	Critical	Enterprise Pilot Playbook v2.0	Expanded to full operational playbook: RACI matrix, 10-week timeline, 8 metric collection procedures, rollback drill script, go/no-go decision matrix with weighted scoring, evidence package template	Closed
F-10	No reading-order guide for document hierarchy	Low	Master Architecture v11.1 §How to read	Added five-tier reading-order guide at start of Master Architecture	Closed
F-11	No competitive positioning	Medium	Framework Overview v1.8 §15	Added Section 15 with competitive positioning against Prisma AIRS, Zenity, Lasso Security, Gravitee	Closed
F-12	Design principles lack rationale	Low	Master Architecture v11.1 §5	Expanded each of the six principles with the failure pattern that motivates them	Closed
F-13	Observability and autonomy scale overclaimed as differentiators	Low	Framework Overview v1.8 §3	Clarified that OpenTelemetry and A0–A4 are intentionally standards-aligned, not proprietary differentiators	Closed
F-14	ATK Reference Implementation Pack document describes FastAPI but code doesn't match	Critical	ATK Reference Implementation Pack v2.0	Complete rewrite: document now accurately describes the FastAPI service, JWT tokens, OPA integration, MCP stub, and workbench simulation that exist in the code	Closed
F-15	No OPA test cases	Medium	arhia_atk_v2/policy/authz_test.rego	Created 6 test cases: happy path, zone deny, classification deny, AIBOM deny, drift degrade, hash invalid	Closed
F-16	Annexes H, I, J missing from Compendium (gap in numbering)	High	Annex Compendium v11.1.1	Added Annexes H (MCP interoperability summary), I (Incident management and escalation), J (Data classification and zoned execution). Master Architecture	Closed

				annex register updated.	
F-17	policy_evaluate() uses Python if/elif, not OPA	High	arhia_atk_service.py v2.1	Added OPA/Rego evaluation via subprocess with automatic Python fallback. Documented dual-path approach in README and ATK Pack.	Closed
F-18	AIBOM validation is superficial vs Annex K.2 spec	Medium	arhia_atk_service.py v2.1	Implemented validate_aibom() with full 7-check sequence per Annex K.2: signature, hash, zone_allowance, approval_status, risk_classification, staleness.	Closed
F-19	allow_with_restrictions and require_human_approval not implemented	Medium	arhia_atk_service.py v2.1, demo.py v2.1	All 6 ATK decisions now implemented. Added /trust/workbench-approve endpoint. Demo script exercises all 6 scenarios.	Closed
F-20	JWT verify_aud=False in interceptor, weak security posture	Medium	mcp_interceptor.py v2.1, arhia_atk_service.py v2.1	Audience verification enabled when mcp_server_id provided. Prominent security warning block added to source. Startup warnings on demo secrets.	Closed
F-21	Rego reason_codes not mutually exclusive, quarantine missing	Medium	authz.rego v2.1, authz_test.rego v2.1	Rewritten with guard conditions ensuring mutual exclusivity. Correct precedence: quarantine > degrade > deny. 11 test cases including precedence and exclusivity.	Closed
F-22	Annexes Q and R are stubs	Low	Annex Compendium v11.1.1	Annex Q expanded with HA topology, ledger replication, failover procedures, DR testing cadence. Annex R expanded with zone cost/risk matrix, Core-M0 sizing, evidence obligations.	Closed
F-23	No integration tests, Dockerfile, or CI pipeline	Low	test_integration.py, Dockerfile	Added 22-test integration suite, Dockerfile with optional OPA binary, health check. README	Closed

				documents CI and Docker usage.	
F-24	Ledger has no external tamper protection	Low	arhia_atk_service.py v2.1	Added HMAC-SHA256 signing per entry with separate key. Added /trust/ledger/verify endpoint. verify_ledger_integrity() checks chain + HMAC. Security notes document HSM requirement for production.	Closed

Summary: 24 findings identified across two audit passes. First pass (v11.1): 4 Critical, 3 High, 5 Medium, 3 Low (15 findings, all closed). Second pass (v11.1.1): 2 High, 4 Medium, 3 Low (9 findings, all closed). All 24 findings CLOSED.

End of Remediation Traceability Matrix.